

Les pare-feu

Stéphane Gill

Stephane.Gill@CollegeAhuntsic.qc.ca

Table des matières

Introduction.....	3
Les services via Internet.....	3
Les services interdits.....	4
La zone démilitarisée.....	5
La définition de la DMZ.....	5
Les systèmes à placer dans la DMZ.....	6
Les architectures de DMZ.....	6
L'architecture avec routeur et pare-feu.....	6
L'architecture avec pare-feu unique.....	7
L'architecture avec double pare-feu.....	8
L'élaboration des règles du pare-feu.....	9
NetFilter/Iptables.....	9
Principes du filtrage de paquets.....	9
Les tables et les chaînes.....	10
Afficher les règles.....	12
Effacer des règles.....	12
Ajouter une règle.....	13
Insérer une règle.....	14
Définir une règle par défaut.....	14
Stockage de l'information.....	14
Pare-feu simple.....	15
Pare-feu traditionnel.....	15
Règles dynamiques.....	16
Balayeur de port.....	17

Document écrit par Stéphane Gill

© Copyright 2013 Stéphane Gill

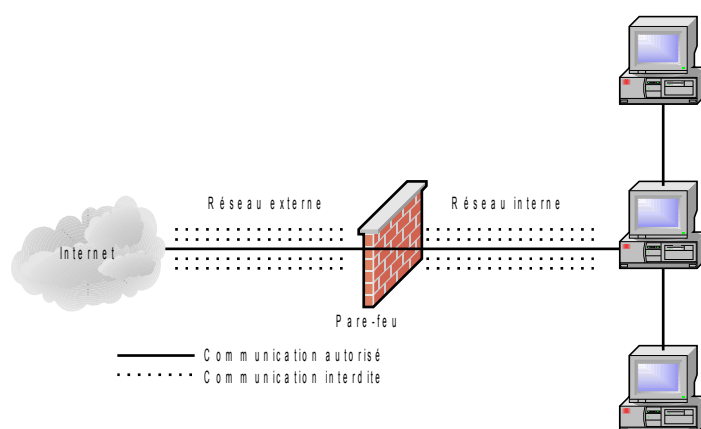
Ce document est soumis à la licence GNU FDL. Permission vous est donnée de distribuer et/ou modifier des copies de ce document tant que cette note apparaît clairement.

Journaux.....	17
L'interface FireWall Builder.....	18
Références.....	18

Introduction

Un pare-feu (firewall en anglais), est un système physique ou logique servant d'interface entre un ou plusieurs réseaux afin de contrôler et, éventuellement, bloquer la circulation des paquets de données. Il s'agit donc d'une machine comportant au minimum deux interfaces réseau :

- une interface pour le réseau à protéger (réseau interne); et
- une interface pour le réseau externe.



Le pare-feu est donc un élément important d'une architecture Internet sécuritaire.

Les services via Internet

La première question à laquelle on doit répondre en ce qui concerne l'architecture Internet est: Quels services doit-on offrir aux clients et aux employés de l'entreprise.

Service	Description
SMTP	Le courrier électronique
HTTP (port 80) HTTPS (port 443)	L'accès au Web
FTP (port 21 et 22)	Transfert de fichier
Telnet (port 23) et SSH (port 22)	Sessions interactives sur systèmes

	distants
POP-3 (port 110) IMAP (port 143)	Accès à des comptes de messagerie distants
NNTP (port 119)	Accès à des serveurs de <i>news</i>
DNS	Résolution de noms
ICMP	Messages de contrôle Internet (Ping)
NTP	Accès à un serveur de temps

Les services interdits

L'architecture Internet doit être conçue pour satisfaire les services requis et les services non nécessaires ne doivent pas être proposés. En conservant l'architecture Internet de cette façon, on élimine un certain nombre de services qui représentent un risque.

Les services à risques qu'il est préférable de ne pas offrir sont présentés dans le tableau suivant :

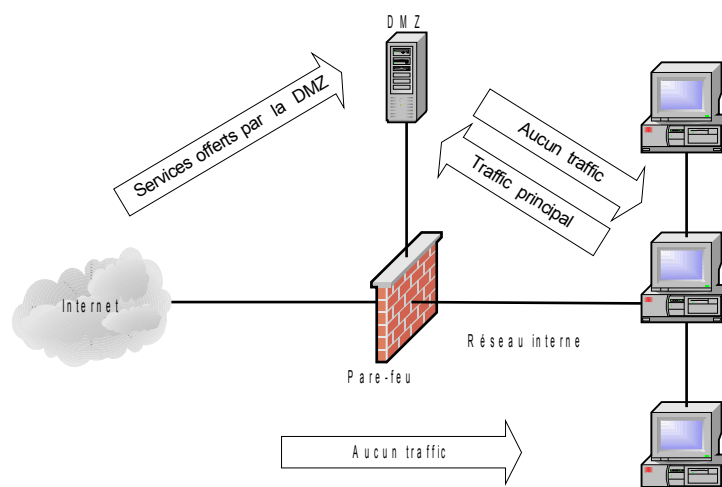
Service	Description
NetBios (port 135, 137, 138 et 139)	Partage de fichiers et commandes à distance de Windows
RPC (port 111)	Appels de procédure à distance (Unix)
NFS (port 2049)	Partage de fichiers Unix
X (port 6000 à 6100)	Environnement de fenêtre X Window
rlogin (port 513), rsh (port 514) et rexec (port 512)	Exécution de commande à distance sans mot de passe
telnet (port 23)	Non recommandé car l'UserID et le mot de passe sont en clair sur Internet et peuvent donc être récupérés. Il est recommandé d'utiliser SSH
FTP (port 21 et 22)	Non recommandé pour les mêmes raisons que telnet. Transférer les fichiers avec SSH (sftp)
TFTP (port 69)	Identique à FTP, mais ne demande ni UserID, ni mot de passe

Netmeeting	Potentiellement dangereux car il exige l'ouverture de numéros de ports élevés pour bien fonctionner. Au lieu d'ouvrir ces ports, il vaut mieux utiliser un proxy
Remote Control Protocols	Regroupant des programmes comme PC Anywhere et VNC. Si ces protocoles sont nécessaires aux utilisateurs distants pour contrôler les systèmes internes, alors ils doivent passer par une connexion VPN
SNMP (Simple Network Management Protocol) (port 169)	Peut être utilisé pour la gestion du réseau interne, mais ne doit pas être utilisé à partir de sites distants

La zone démilitarisée

Le terme « DMZ » (demilitarized zone) ou « zone démilitarisée » désigne communément une partie du réseau que l'on considère peu fiable. La DMZ est une zone du réseau qui sépare les systèmes accessibles par les internautes des systèmes dont l'accès est réservé aux usager du réseau interne.

La définition de la DMZ



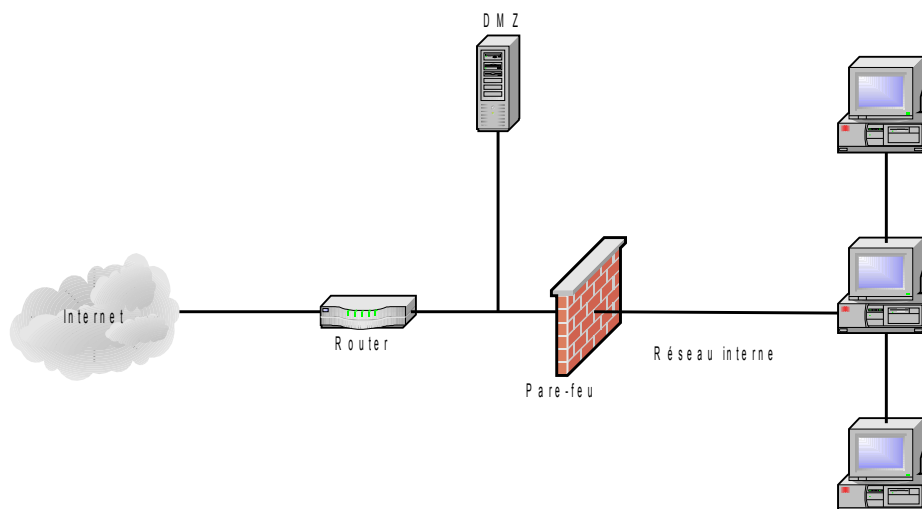
Les systèmes à placer dans la DMZ

- Les serveurs de courrier électronique;
- Les serveurs Web;
- Les systèmes accessibles de l'extérieur (SSH); et
- Les systèmes de contrôle (DNS, NTP, ...).

Les architectures de DMZ

Il existe de nombreuses architectures de DMZ. Comme la plupart des aspects liés à la sécurité, chaque architecture présente des avantages et des inconvénients, et déterminer laquelle répondra le mieux aux besoins de chaque entreprise est problématique.

L'architecture avec routeur et pare-feu



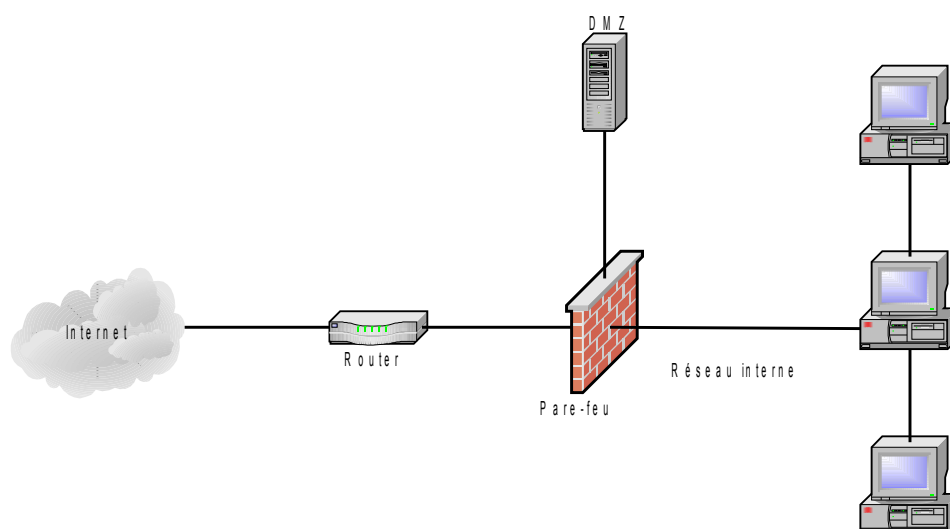
Règles

Règles	IP source	IP destinataire	Service	Action
1	Serveur de messagerie interne	Serveur de messagerie	SMTP	Accepter

Les pare-feu

2	Réseau interne	Tous	HTTP, HTTPS, FTP, Telnet, SSH.	Accepter
3	DNS interne	Tous	DNS	Accepter
4	Tous	Tous	Tous	Refuser

L'architecture avec pare-feu unique

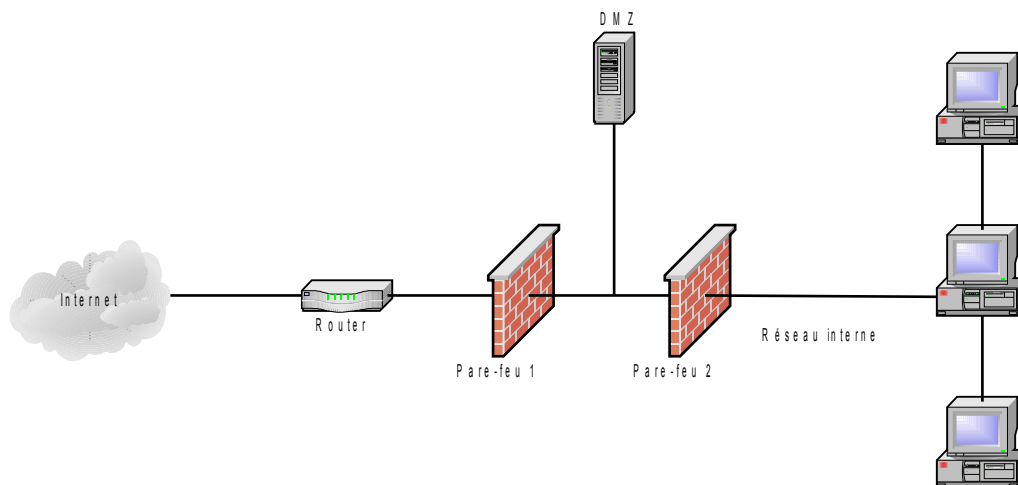


Règles

Règles	IP source	IP destinataire	Service	Action
1	Tous	Serveur Web	HTTP	Accepter
2	Tous	Serveur de messagerie	SMTP	Accepter
3	Serveur de messagerie interne	Tous	SMTP	Accepter
4	Réseau interne	Tous	HTTP, HTTPS, FTP, Telnet, SSH.	Accepter
5	DNS interne	Tous	DNS	Accepter

6	Tous	Tous	Tous	Refuser
---	------	------	------	---------

L'architecture avec double pare-feu



Règles premier pare-feu

Règles	IP source	IP destinataire	Service	Action
1	Tous	Serveur Web	HTTP	Accepter
2	Tous	Serveur de messagerie	SMTP	Accepter
3	Serveur de messagerie interne	Tous	SMTP	Accepter
4	Réseau interne	Tous	HTTP, HTTPS, FTP, Telnet, SSH.	Accepter
5	DNS interne	Tous	DNS	Accepter
6	Tous	Tous	Tous	Refuser

Règles deuxième pare-feu

Règles	IP source	IP destinataire	Service	Action
1	Serveur de messagerie interne	Serveur de messagerie	SMTP	Accepter

2	Réseau interne	Tous	HTTP, HTTPS, FTP, Telnet, SSH.	Accepter
3	DNS interne	Tous	DNS	Accepter
4	Tous	Tous	Tous	Refuser

L'élaboration des règles du pare-feu

L'élaboration de règles adéquates peut être aussi important pour un pare-feu que le choix du matériel. La plupart des pare-feu décident d'accepter ou de rejeter les paquets en fonction de la « première concordance » (first match) qu'ils trouvent. Pour l'élaboration des règles, un algorithme basé sur la première concordance impose ainsi que les règles les plus spécifiques soient placées en tête et celles plus générales en dernier. Cet ordre garantit que les règles les plus générales ne masquent pas les règles les plus spécifiques.

NetFilter/Iptables

NetFilter/Iptables est un outil permettant le filtrage de paquets réseau. Le filtrage des paquets est le processus qui contrôle les paquets réseau lorsqu'ils entrent, traversent et sortent de la pile réseau dans le noyau. Les noyaux antérieurs à la version 2.4 utilisaient ipchains pour le filtrage de paquets. Iptables (aussi appelé netfilter), est semblable à la commande ipchains si ce n'est qu'elle augmente le degré de contrôle disponible lors du filtrage des paquets.

Cette section décrit en détails les principes des techniques de filtrage de paquets, en présentant les différentes options disponibles avec iptables et en montrant comment maintenir l'intégrité des règles de filtrage entre chaque démarrage de votre système.

Principes du filtrage de paquets

Le principe est assez simple à comprendre, il est malheureusement moins simple à mettre en oeuvre.

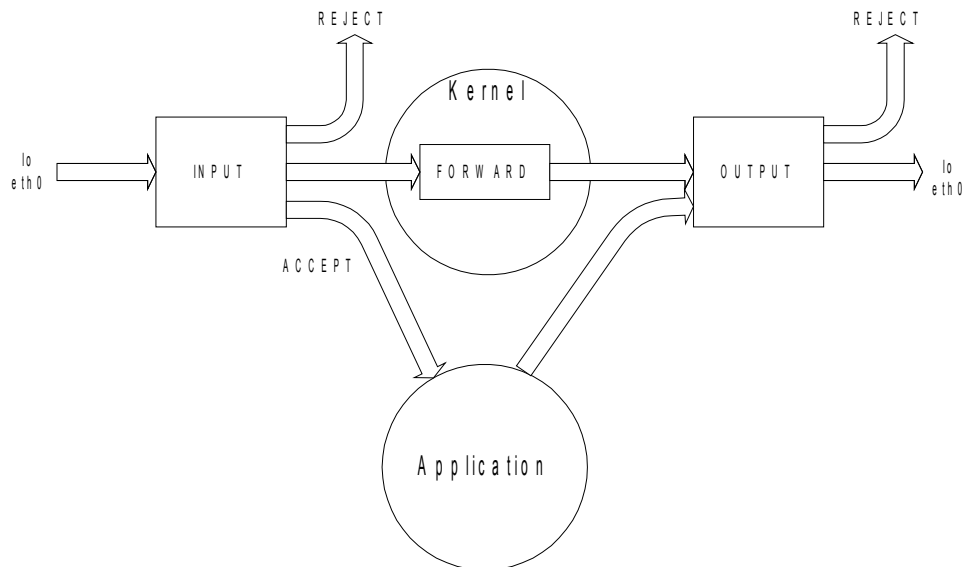
Un paquet arrive sur votre machine (on parle de paquet entrant INPUT), vous devez alors choisir ce que vous en faites. Vous pouvez l'accepter (ACCEPT), vous pouvez le rejeter (REJECT) ou le renier (DENY).

La différence entre les deux derniers modes, est de prévenir ou non l'envoyeur, que son paquet a été refusé (avec REJECT on prévient, mais pas avec DENY).

Une fois le paquet arrivé sur votre machine, il peut être relayé (FORWARD) sur une autre carte réseau, par exemple. Enfin arrivé sur cette deuxième carte réseau, il peut être autorisé ou non à sortir.

Cette dernière notion est souvent plus compliquée à comprendre, toutefois imaginez que votre machine autorise un type de paquet, un pirate arrive à prendre une partie du contrôle de votre machine, tant qu'il n'est pas en mesure de modifier les règles, il ne peut pas rebondir sur les autres machines de votre réseau.

Enfin dans le mode FORWARD on dispose d'une option supplémentaire qui est MASQ, ce qui permet de masquer les adresses IP des machines se trouvant dans votre réseau local. Cela permet, entre autre, de laisser croire à votre fournisseur Internet que vous disposez que d'une seule machine pouvant se connecter à l'internet.



Les tables et les chaînes

Les règles de filtrage sont entreposées dans des tables. Iptables contient les trois tables suivantes:

- **filter** — table par défaut pour le traitement des paquets réseau.
- **nat** — table utilisée pour modifier les paquets qui créent une nouvelle connexion.

- **mangle** — table utilisée pour la modification de types spécifiques de paquets.

Chacune de ces tables comporte à son tour un groupe de chaînes qui correspondent aux actions effectuées par *netfilter* sur le paquet.

Les chaînes de la table *filter* sont les suivantes:

- **INPUT** — cette chaîne s'applique aux paquets reçus via une interface réseau.
- **OUTPUT** — cette chaîne s'applique aux paquets expédiés par la même interface réseau qui a reçu les paquets.
- **FORWARD** — cette chaîne s'applique aux paquets reçus par une interface réseau et expédiés par une autre interface.

Les chaînes pour la table *nat* sont les suivantes:

- **PREROUTING** — cette chaîne modifie les paquets reçus via une interface réseau lorsqu'ils arrivent.
- **OUTPUT** — cette chaîne modifie les paquets générés localement avant qu'ils ne soient routés par une interface réseau.
- **POSTROUTING** — cette chaîne modifie les paquets avant qu'ils ne soient expédiés par une interface réseau.

Les chaînes pour la table *mangle* sont les suivantes:

- **PREROUTING** — cette chaîne modifie les paquets reçus par une interface réseau avant qu'ils ne soient routés.
- **OUTPUT** — cette chaîne modifie les paquets générés localement avant qu'ils ne soient routés via une interface réseau.

Chaque paquet reçu ou expédié par un système Linux est soumis à au moins une table.

Chaque paquet, avant de sortir d'une chaîne, peut être soumis à un très grand nombre de règles. La structure et le rôle de ces règles peuvent changer, mais elles visent généralement à identifier un paquet en provenance ou à destination d'une adresse IP donnée ou d'un groupe d'adresses, lors de l'utilisation d'un protocole ou d'un service de réseau particulier.

Indépendamment de leur destination, lorsque les paquets correspondent à une règle précise d'une des tables, ils se voient assigner une cible font l'objet d'une certaine action. Si la règle spécifie une cible de type ACCEPT, un paquet est accepté après avoir été contrôlé avec succès, et peut procéder vers sa destination en évitant le reste des contrôles de la règle. Si une règle spécifie une cible de type DROP le paquet est abandonné et se voit refuser l'accès au système; rien n'est donc renvoyé à l'hôte qui a expédié le paquet. Si une règle spécifie une cible de type QUEUE, le paquet est mis en attente dans l'espace-utilisateur (ou 'user-space'). Finalement, si une règle spécifie une cible de type REJECT, le paquet est "abandonné" mais par rejet et dans ce cas, un "paquet d'erreur" est renvoyé à l'expéditeur.

Chaque chaîne dispose d'une politique par défaut pour accepter (ACCEPT), abandonner (DROP), rejeter (REJECT) ou mettre en attente (QUEUE). Si aucune des règles présentes dans la chaîne ne s'applique au paquetage, celui-ci est traité en fonction de la politique par défaut de la chaîne.

La commande *iptables* permet de configurer ces tables et d'en créer de nouvelles si nécessaire

Afficher les règles

```
iptables -L <nom-de-chaîne> -t <nom-de-table>
```

Cette commande affiche la liste complète des règles dans la chaîne indiquée. Pour obtenir une liste de toutes les règles de toutes les chaînes contenues dans la table par défaut, *filter*, ne précisez ni chaîne, ni table.

Exemple 1 :

Afficher les règles de la table filter.

```
iptables -L
```

Exemple 2 :

Afficher les règles de la table nat

```
iptables -L -t nat
```

Effacer des règles

```
iptables -F <nom-de-chaîne> -t <nom-de-table>
```

Cette commande supprime la chaîne sélectionnée, entraînant, l'élimination de toutes les règles de la chaîne. Si aucune chaîne n'est spécifiée, cette commande supprime chaque règle de chaque chaîne de la table spécifiée.

Exemple 1 :

Effacer toutes les règles de toutes les chaînes de la table *filter*.

```
iptables -F
```

Exemple 2 :

Effacer toutes les règles de la chaîne INPUT de la table *filter*.

```
iptables -F INPUT
```

Ajouter une règle

```
iptables -t <nom-de-table> -A <nom-de-chaîne> -s <source>  
-d <destination> -p <protocole> --dport <port> -j <cible>
```

Cette commande ajoute une règle *iptables* à la fin d'une chaîne donnée. On l'utilise pour ajouter simplement une règle lorsque l'ordre des règles à l'intérieur de la chaîne n'est pas primordial.

La cible est l'action à prendre. On doit spécifier la cible pour chaque règle d'une chaîne.

Cible	Description
ACCEPT	accepter les paquets
DROP	interdire l'accès
REJECT	interdire l'accès avec notification
QUEUE	envoyer les paquets à l'espace usager
RETURN	aller à la fin de la chaîne

Exemple 1 :

```
iptables -A FORWARD -s 192.168.1.0/24 -d 192.168.2.4 -p tcp -dport 80 -j  
ACCEPT
```

Exemple 2 :

Refuser les *ping* provenant de votre coéquipier sur votre machine.

Insérer une règle

```
iptables -t <nom-de-table> -I <nom-de-chaîne> -s <source>  
-d <destination> -p <protocole> --dport <port> -j <cible>
```

Cette commande insère une règle à l'intérieur d'une chaîne, à un point précis, spécifié par une valeur paire définie par l'utilisateur. Si aucun numéro n'est spécifié, *iptables* placera la commande au tout début de la chaîne.

Prêtez particulièrement attention à l'option (-A ou -I) utilisée lors de l'ajout d'une règle. L'ordre dans lequel les règles apparaissent dans une chaîne est très important quand il s'agit de définir quelles règles appliquer à quels paquets.

Définir une règle par défaut

```
iptables -t <nom-de-table> -P <nom-de-chaîne> cible
```

Cette commande définit la politique par défaut d'une chaîne donnée, de sorte que lorsque des paquets traversent une chaîne entière sans satisfaire à une règle, ils seront envoyés à une cible donnée, telle que ACCEPT ou DROP.

Exemple :

```
iptables -P INPUT DROP
```

Stockage de l'information

Les règles créées avec la commande *iptables* sont stockées en mémoire. Si le système est redémarré après la configuration des différentes règles *iptables*, elles seront perdues. Pour que des règles de filtrage réseau soient conservées lors d'un redémarrage, elles doivent être enregistrées. Pour ce faire, connectez-vous en tant que super-utilisateur (ou root) et tapez:

```
/sbin/service iptables save
```

Cette commande exécute le script initial (init script) *iptables* qui lance le programme */sbin/iptables-save* et enregistre la configuration actuelle de *iptables* dans le fichier */etc/sysconfig/iptables*. Ce fichier ne devrait être lisible que par le super-utilisateur.

Au prochain démarrage, le script initial *iptables* fera appliquer les règles enregistrées dans */etc/sysconfig/iptables* grâce à la commande */sbin/iptables-restore*.

Alors qu'il est toujours préférable de tester une nouvelle règle *iptables* avant de l'enregistrer dans le fichier */etc/sysconfig/iptables*, il est possible de copier des règles *iptables* dans ce fichier à partir d'une version de ce fichier provenant d'un autre ordinateur. Cette opération permet de distribuer facilement un ensemble de règles *iptables* à de multiples ordinateurs.

Si vous distribuez le fichier */etc/sysconfig/iptables* vers d'autres machines, il suffit de taper

```
/sbin/service iptables restart
```

pour que ces nouvelles règles soient mises en oeuvre.

Pare-feu simple

```
iptables -F INPUT
iptables -P INPUT DROP
```

Ce pare-feu est très sécuritaire, en effet toutes les connections entrantes seront bloquées.

```
ping 127.0.0.1
```

Pare-feu traditionnel

```
#!/bin/bash
if [ "$1" = "start" ]
then
    echo "Démarrage du pare feu..."
    iptables -P INPUT DROP
    iptables -A INPUT -i ! eth0 -j ACCEPT
elif [ "$1" = "stop" ]
then
    echo "Arrêt du pare feu..."
    iptables -F INPUT
    iptables -P INPUT ACCEPT
fi
```

Les pare-feu

Cette nouvelle règle permet d'accepter les connexions entrantes de toutes les interfaces sauf celles provenant de *eth0*

```
ping 127.0.0.1  
lynx www.collegeahuntsic.qc.ca
```

Pour permettre le téléchargement de page web il faut ajouter la règle suivante:

```
iptables -A INPUT -p tcp --sport 80 -j ACCEPT
```

Comme la majorité du trafic Web utilise le port 80, cette règle permet donc de télécharger des pages Web. Le trafic provenant du port 81 *http://www.foo.com:81*

ssh

http

Autorise le trafic provenant du port 80. http fw

Et le serveur DNS?

```
iptables -A INPUT -p udp -s yourry --source-port domain -j ACCEPT  
iptables -A INPUT -p tcp -s yourry --source-port domain -j ACCEPT
```

domain voir fichier /etc/services

Règles dynamiques

iptables a la capacité de créer des règles de comparaison fondées sur l'état des paquets. Les quatre états d'un paquet sont décrits au tableau suivant.

État	Description
NEW	Les paquets ayant initié une nouvelle connexion.
ESTABLISHED	Les paquets qui appartiennent déjà à une connexion ouverte, et sont donc envoyés en réponse à d'autres paquets.
RELATED	Les paquets qui initient une nouvelle connexion mais qui sont reliés à une connexion existante.
INVALID	Les paquets qui n'ont aucun sens dans le contexte de la connexion existante.

Dans l'exemple du pare-feu traditionnel tout le trafic entrant sur le port 80 est autorisé, pas seulement le trafic que nous avons initié. Il est donc souhaitable d'utiliser la règle suivante plutôt que d'autoriser tous les paquets

```
iptables -A input -m state --state ESTABLISHED,RELATED -j ACCEPT
```

Cette règle autorise tout le trafic entrant que nous avons initié peu importe le port.

Balayeur de port

L'option « *--reject-with tcp-reset* » et « *--reject-with icmp-port-unreachable* » de la cible REJECT permet de rendre le pare-feu totalement transparent vis-à-vis des balayeurs de port. Voici un exemple utilisant cette option.

```
iptables -A INPUT -p tcp -i eth0 -j REJECT --reject-with tcp-reset
iptables -A INPUT -p udp -i eth0 -j REJECT --reject-with icmp-port-unreachable
```

Journaux

```
iptables -A INPUT -j LOG --log-prefix "MON pare-feu"
```

La cible LOG permet la tenue de journaux. LOG est une cible spéciale, normalement lorsqu'un paquet est ACCEPT, DROP ou DENY aucune autre règle n'est traitée. Lorsque la règle est respectée une entrée dans le journal est inscrite et le paquet passe à la règle suivante.

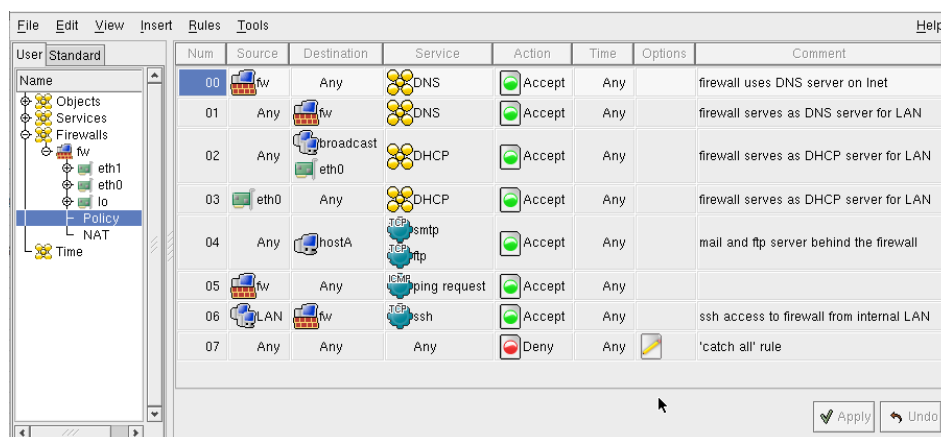
L'option « *--log-prefix* » permet l'ajout de texte dans le journal du système.

Pour minimiser le nombre de lignes semblables dans les journaux on utilise plutôt la commande suivante :

```
iptables -A INPUT -m state --state INVALID iptables -m limit --limit 5/minute -j LOG --log-prefix "MON pare-feu"
```

L'interface FireWall Builder

FireWall Builder est une interface graphique qui permet de paramétrer et gérer facilement un ou plusieurs pare-feu. Les plate-formes supportées sont : iptables, ipfilters, OpenBSD PF et Cisco PIX. La figure suivante présente l'interface graphique de cet utilitaire. FireWall Builder est disponible sur le site www.fwbuilder.org.



Références

Thomas W. Shinder, « Sécurité sous Windows 2000 Server », Eyrolles, 2002.

Stefen Norberg, « Securing Windows NT/2000 Servers for the Internet », O'Reilly, 2001.

Elizabeth Zwicky, Simon Cooper et Brent Chapman, « Building Internet Firewalls », deuxième édition, O'Reilly, 2000.

Eric Maiwald, « Sécurité des réseaux », Campus press, 2001.

Aron Hsiao, « Sécurité sous Linux », Campus press, 2001.

RedHat

IBM developer Work